Secure Configuration and Hardening Standard

Mirqab Digital Solutions Company

Document Control

Field	Value
Document title	Secure Configuration and Hardening Standard
Document identifier	MDS-CS-STD-003
Document class	Technical Standard (Tier 3)
Classification	Internal — Restricted
Version	4.4
Document owner	Head of Cybersecurity Engineering
Technical authority	Chief Information Security Officer
Approving authority	Cybersecurity Committee (CSC)
Approval reference	CSC/2026/01-09
Date of approval	22 Rajab 1447H / 11 January 2026G
Effective date	1 Sha'ban 1447H / 20 January 2026G
Next scheduled review	1 Sha'ban 1448H / 9 January 2027G
Parent documents	MDS-CS-POL-001; MDS-CS-POL-002

1. Purpose

1.1 This Standard sets the mandatory requirements for the secure configuration of technology assets, the management of technical vulnerabilities, the application of patches, the treatment of unsupported technology, and the control of change. It is the sole authoritative source in this corpus for configuration baselines, vulnerability remediation timelines and change control requirements.

1.2 This Standard gives effect to the secure-by-design-and-by-default principle at [MDS-CS-POL-001 §7.5] and the deny-by-default principle at [§7.3].

2. Scope

2.1 This Standard applies to every technology asset in the Company estate, including: servers, workstations, laptops and mobile devices; network and security appliances; hypervisors and container platforms; databases, middleware and message brokers; operating systems and their components; cloud resources and managed services; container images; infrastructure-as-code definitions; and the operational technology in scope of [MDS-CS-POL-002 §13], subject to §13.6 of that Manual.

2.2 The Standard applies in all environments. Non-production environments are in scope; a lower baseline is not permitted merely because an environment is non-production, although §7.2 sets different remediation timelines by environment.

3. Definitions

3.1 Terms have the meanings at [MDS-CS-REF-001], in particular: *baseline*, *golden image*, *configuration drift*, *authenticated scan*, *actively*

exploited vulnerability, and *emergency change*.

4. Roles

4.1 The **Head of Cybersecurity Engineering** owns this Standard and approves every baseline.

4.2 The **technical custodian** of an asset, as recorded under [MDS-CS-POL-002 §4.2], is accountable for applying the baseline, remediating vulnerabilities within the timelines at §7.2, and maintaining the asset within vendor support.

4.3 The **business information asset owner** is accountable for accepting any residual risk arising from a deviation, through the exception process at [MDS-CS-POL-001 §10].

5. Configuration Baselines

5.1 Every asset type in the Company estate shall have a documented, approved configuration baseline. An asset shall not be deployed into any environment before a baseline exists for its type and has been applied.

5.2 Baselines shall be derived from a recognised secure configuration benchmark — Center for Internet Security Benchmarks at Level 1 as a minimum, or the vendor's published security configuration guidance where no benchmark exists — and shall then be adjusted for the Company environment. Every deviation from the source benchmark shall be documented with its justification in the baseline document itself.

5.3 Baselines shall be approved by the Head of Cybersecurity Engineering before use, and shall be version-controlled with a documented change history.

5.4 Baselines shall be reviewed at intervals not exceeding **twelve (12) months**, and additionally within **sixty (60) calendar days** of the

publication of a new major version of the source benchmark or of the underlying product.

5.5 Every baseline shall address, as a minimum: removal or disabling of unnecessary services, protocols, daemons, roles, features and sample content; closure of unnecessary network ports; removal or disabling of default and guest accounts and change of default credentials per [MDS-CS-STD-001 §8.6]; the minimum authentication configuration required by [MDS-CS-STD-001]; the cryptographic configuration required by [MDS-CS-STD-002], including approved protocol versions and cipher suites; the audit logging configuration required by [MDS-CS-STD-004 §5]; time synchronisation per [MDS-CS-STD-004 §8]; host firewall configuration; malicious code protection per §10; secure boot and firmware protection where supported; file integrity monitoring on systems in criticality Tier 1; and the administrative access restrictions at [MDS-CS-STD-001 §7].

5.6 Privileged access workstations shall be built to a dedicated hardened baseline that additionally: removes email, instant messaging and general web browsing capability; permits outbound network connections only to a defined list of management endpoints; enforces application allow-listing in default-deny mode; prohibits removable media entirely; requires AAL-3 authentication at logon per [MDS-CS-STD-001 §5.3.1]; prohibits the workstation being used for any non-administrative task; and is rebuilt from the golden image at intervals not exceeding **one hundred and eighty (180) calendar days**.

5.7 Systems shall be built from an approved **golden image** where one exists. Golden images shall be rebuilt and re-hardened at intervals not exceeding **thirty (30) calendar days** so that newly deployed systems are not deployed already requiring patches, and shall be scanned for vulnerabilities before release.

5.8 Infrastructure defined as code shall have its definitions stored in version control, peer-reviewed before merge per [MDS-CS-STD-006 §5.4], and scanned automatically for insecure configuration before deployment. Manual changes to infrastructure that is managed as code are prohibited outside an emergency change under §9.6, and shall be reconciled back into code within **five (5) business days**.

5.9 Container images shall be built from an approved minimal base image, shall not run as root, shall not include a shell or package manager in the production image where the runtime permits, and shall be scanned per [MDS-CS-STD-006 §8.4] before being admitted to a production registry.

---

6. Configuration Compliance and Drift

6.1 Compliance with the applicable baseline shall be measured automatically for every asset at intervals not exceeding **twenty-four (24) hours**, and results shall be reported to the platform required by [MDS-CS-STD-004].

6.2 Configuration drift from an approved baseline shall be alerted to the technical custodian and shall be remediated within: **seven (7) calendar days** for a setting classified in the baseline as security-critical; **thirty (30) calendar days** otherwise. Drift on a system in criticality Tier 1 that affects a security-critical setting shall additionally raise an alert per [MDS-CS-STD-004 §7.2].

6.3 An asset shall not be admitted to a production network until it evidences baseline compliance. Assets found in production without an applied baseline shall be treated as an incident under [MDS-CS-POL-001 §8].

6.4 Baseline compliance percentage by asset class shall be reported monthly to the Cybersecurity Operations Forum and quarterly to the Cybersecurity Committee, using the metric at [MDS-CS-REF-003 Annex G].

---

7. Vulnerability and Patch Management

7.1 Discovery

7.1.1 Vulnerability scanning shall be performed at the following minimum frequencies:

Target	Frequency	Type
Internet-facing assets	Daily	Unauthenticated, plus authenticated weekly
Cardholder data environment	Weekly	Authenticated
Internal production servers and network devices	Weekly	Authenticated
End-user endpoints	Weekly	Authenticated, via the endpoint agent
Non-production environments	Monthly	Authenticated
Container images	On every build, and re-scanned in the registry weekly	Image composition analysis
Cloud resource configuration	Continuous	Cloud posture management per [MDS-CS-STD-005 §8]

7.1.2 External attack surface discovery shall run continuously and shall reconcile discovered internet-facing assets against the inventory required by [MDS-CS-POL-002 §4.3]. An internet-facing asset not present in the inventory shall be investigated within **twenty-four (24) hours**.

7.1.3 Scanning shall be authenticated wherever technically possible. An unauthenticated scan shall not be reported as evidence of the absence of vulnerabilities.

7.1.4 Assets that cannot be scanned by the standard tooling — including certain operational technology in scope of [MDS-CS-POL-002 §13] — shall be assessed by an alternative method, such as passive network monitoring or vendor advisory review, at the same frequency.

7.2 Remediation timelines

7.2.1 Vulnerabilities shall be remediated within the following maximum periods, measured from the date the vulnerability is first identified in the Company estate by any means — scan, vendor advisory, threat intelligence per [MDS-CS-POL-002 §10.11], penetration test, or third-party notification:

Severity (CVSS v3.1 base score)	Internet-facing assets, and the cardholder data environment	Internal production assets	Non-production assets
Critical (9.0 – 10.0)	**72 hours**	7 calendar days	30 calendar days
High (7.0 – 8.9)	7 calendar days	14 calendar days	60 calendar days
Medium (4.0 – 6.9)	30 calendar days	60 calendar days	120 calendar days
Low (0.1 – 3.9)	90 calendar days	180 calendar days	Next scheduled maintenance

7.2.2 The base score shall be adjusted using environmental and temporal metrics where the Company's context materially changes the risk. An adjustment that **lowers** a severity shall be documented, shall state the compensating factor relied upon, and shall be approved by the Head of Cybersecurity Engineering. An adjustment that **raises** a severity requires no approval and takes effect immediately.

7.2.3 Where a vendor patch is not available within the applicable period, the technical custodian shall implement a documented mitigation — configuration change, virtual patching at the network or application layer, service disablement, or isolation — within the same period, and shall raise an exception per [MDS-CS-POL-001 §10] for the residual exposure until the patch is applied.

7.2.4 Remediation is not complete until a subsequent authenticated

scan or equivalent verification confirms the vulnerability is no longer present. Closure on the basis of a change record alone is not permitted.

7.3 Prioritisation and exploitation

7.3.1 Where a vulnerability is subject to **active exploitation** — evidenced by an advisory of the National Cybersecurity Authority, a recognised known-exploited-vulnerability catalogue, credible threat intelligence assessed under [MDS-CS-POL-002 §10.12], or observation within the Company estate — the timelines at §7.2.1 do not apply and §7.4 applies instead, irrespective of the CVSS score.

7.3.2 A vulnerability with a working public exploit but no evidence of active exploitation shall be treated as one severity level higher than its base score for the purpose of §7.2.1.

7.4 Emergency response to actively exploited vulnerabilities

7.4.1 On confirmation that a vulnerability meeting §7.3.1 affects the Company estate, the following maximum periods apply, measured from the Company's confirmation of applicability:

Asset location	Mitigate or patch within
Internet-facing assets, and the cardholder data environment	**24 hours**
Internal production assets	72 hours
All other assets	7 calendar days

7.4.2 Remediation under this clause shall proceed as an emergency change under §9.6 and does not require prior Change Advisory Board approval.

7.4.3 Where the applicable period cannot be met, the affected service shall be isolated or withdrawn from service until it can be remediated,

unless the CISO decides otherwise in writing having weighed the business impact. That decision shall be reported to the Cybersecurity Committee.

7.4.4 The CISO may direct the immediate isolation of any asset presenting an imminent threat, without prior change approval and without the consent of the asset owner.

7.5 Reporting

7.5.1 Open vulnerabilities past their §7.2.1 or §7.4.1 due date shall be reported weekly to the technical custodian's line management, monthly to the Cybersecurity Operations Forum, and quarterly to the Cybersecurity Committee, using the metric at [MDS-CS-REF-003 Annex G].

7.5.2 Findings from penetration testing under [MDS-CS-POL-001 §9.2] shall be entered into the same remediation workflow, with severity mapped to the scale at §7.2.1, and shall be closed on the evidence standard at [MDS-CS-POL-001 §9.6].

---

8. Unsupported and End-of-Life Technology

8.1 Technology that has reached the end of vendor security support shall not be operated in any Company environment. Its removal or upgrade shall be planned at least **twelve (12) months** before the published end-of-support date.

8.2 The Company shall maintain a forward register of end-of-support dates for all products in the estate, reviewed quarterly, and shall report to the Cybersecurity Committee any product reaching end of support within the next twelve months without a funded replacement plan.

8.3 Where continued operation is unavoidable, an exception shall be approved under [MDS-CS-POL-001 §10] at the authority level corresponding to the residual risk, and shall implement all of the

following compensating controls, each with a named owner:

- **8.3.1** network isolation of the asset into a dedicated segment with an explicit, minimal allow-list of permitted flows;
- **8.3.2** removal of all direct user access, with access mediated through a broker or jump host under [MDS-CS-STD-001 §7.4];
- **8.3.3** enhanced monitoring, with the asset's events treated as high-fidelity and alerted on per [MDS-CS-STD-004 §7.2];
- **8.3.4** application allow-listing in default-deny mode on the asset where the platform supports it;
- **8.3.5** virtual patching at the network or application layer for known vulnerabilities affecting it;
- **8.3.6** a documented, funded migration plan with dates, reported to the Cybersecurity Committee at each quarterly meeting until the asset is decommissioned; and
- **8.3.7** where the asset is internet-facing, its withdrawal from internet exposure — an internet-facing unsupported asset shall not be permitted to remain internet-facing under any exception.

8.4 Extended security support purchased from the vendor satisfies §8.1 for the duration of that support, provided it includes security patches for the vulnerabilities in scope of §7.

---

9. Change Management

9.1 Every change to a production system, network, security control or cloud configuration shall be recorded, assessed, authorised, implemented and reviewed through the Company change management process. Undocumented change to production is prohibited.

9.2 A change record shall state: the change description and its purpose; the systems and services affected; the assessed risk, including its cybersecurity impact; the implementation plan; the test evidence; the back-out plan; the verification steps; and the named implementer and approver.

9.3 Changes shall be classified as **standard** (pre-approved, low-risk,

repeatable, executed from a documented procedure), **normal** (requiring Change Advisory Board authorisation), or **emergency** (§9.6).

9.4 Every normal change shall be assessed for cybersecurity impact before authorisation. A change assessed as having a cybersecurity impact shall not proceed without the approval of the Cybersecurity representative on the Change Advisory Board, who holds a veto per [MDS-CS-POL-001 §5.3].

9.5 Changes shall be tested in a non-production environment representative of production before implementation. The person who implements a change into production shall not be the sole person who approved it, per the segregation principle at [MDS-CS-POL-001 §7.2].

9.6 Emergency change. An emergency change may be implemented without prior Change Advisory Board authorisation where delay would cause a service outage, a security compromise, or a breach of the timelines at §7.4. It shall be authorised at the time by the on-call senior manager of the affected platform and the CISO or a delegate for any security-affecting change; shall be recorded in the change system **within four (4) hours** of implementation; and shall be reviewed at the next Change Advisory Board meeting, which shall assess whether the emergency route was justified.

9.7 A change freeze shall apply during periods of elevated business risk as published by IT Service Management. Changes during a freeze require executive authorisation, except emergency changes under §9.6.

9.8 Post-implementation verification shall confirm that the change achieved its purpose and that security controls — logging, authentication, encryption, monitoring agents — remain in place and functioning. Where a change disables a security control temporarily, its restoration shall be verified explicitly and recorded.

9.9 Unauthorised change detected by configuration monitoring under §6 shall be investigated as a potential incident under [MDS-CS-POL-001 §8] and shall not be retrospectively legitimised by raising a change record after the fact.

10. Malicious Code Protection

10.1 Malicious code protection shall be deployed on all servers, endpoints, email gateways, web gateways and file transfer points, and shall be configured to update signatures and detection content automatically at intervals not exceeding **four (4) hours**.

10.2 Protection shall include behavioural and heuristic detection in addition to signature matching, and shall be integrated with the detection platform required by [MDS-CS-STD-004].

10.3 Scanning exclusions shall be approved by the Head of Cybersecurity Engineering, shall be as narrow as possible, shall be documented with justification, and shall be reviewed at intervals not exceeding **one hundred and eighty (180) calendar days**. Exclusion of an entire drive, an entire file type, or a user-writable directory tree is prohibited.

10.4 Email attachments and downloaded files of types capable of carrying executable content shall be detonated in a sandbox before delivery, and macros in files originating from outside the Company shall be blocked by policy.

10.5 Detection of malicious code shall be treated as a cybersecurity incident and reported per [MDS-CS-POL-001 §8.2], whether or not the protection reports successful remediation.

---

11. Compliance, Exceptions and Related Documents

11.1 Compliance shall be measured by the automated mechanisms at §6.1 and §7.1 and reported per §6.4 and §7.5.1.

11.2 Exceptions shall be handled per [MDS-CS-POL-001 §10], and unsupported technology exceptions additionally per §8.3.

11.3 Related documents: [MDS-CS-POL-001 §7.5], §9.2, §10; [MDS-CS-POL-002] §4.10, §7, §10.12, §13; [MDS-CS-STD-001 §7], §8.6; [MDS-CS-STD-002] §5, §6.1; [MDS-CS-STD-004] §5, §7, §8; [MDS-CS-STD-005 §8]; [MDS-CS-STD-006] §5.4, §8.4; [MDS-CS-REF-003 §4] (criticality tiers), Annex G (metrics).

Classification: Internal — Restricted. Synthetic material describing a fictional entity, generated for the testing of automated systems.